

ANEXO VI - Estándar de Seguridad Informática

Marco de aplicabilidad. Definiciones generales

MetroGAS cuenta con una gestión de Seguridad de la Información (SI) cuyo principal objetivo es la preservación y mantenimiento de la confidencialidad, integridad, disponibilidad y continuidad de los sistemas y de la información. A partir de la definición de este marco, los servicios a convenir con los proveedores deberán, promover y mantener niveles de seguridad acordes sobre los datos que administran y a los que acceden con motivo del cumplimiento de sus funciones, incluyendo pero sin limitarse a:

- No divulgar, copiar, transmitir y/o exportar información de las bases de datos de MetroGAS o información de los sistemas, fuera del ámbito de la compañía.
- Hacer uso individual de las cuentas y usuarios que fueran otorgados para la realización de sus tareas.
- La transferencia de información entre ambientes y/o instancias debe hacerse de manera segura. La información de ambientes productivos debe mantenerse resguardada y deberá enmascarse para su uso en otros entornos.
- Se deberá utilizar mecanismos de encriptación de información para la gestión de interfaces.
- Solicitar el consentimiento de MetroGAS para cualquier actividad que requiera accesos de otros terceros o intervenciones externas más allá de las personas que integran el convenio de servicios.
- Se deberá dar aviso inmediato a MetroGAS cuando se detecte un ciberincidente.
- Mantener el debido cuidado profesional sobre cualquier información proporcionada por MetroGAS para el desarrollo de sus funciones.
- Aplicar en la metodología de trabajo las mejores prácticas de seguridad del mercado enmarcadas dentro de los requerimientos de ISO/IEC 27001 de seguridad de la información, ISO 27032 de seguridad en la nube, IEC 62443 de seguridad OT e ISO/IEC 27034 para el desarrollo de sistemas de aplicación.
- Comprometerse al cumplimiento y requisitos legales sobre privacidad y protección de datos personales (Ley 25.326), delitos informáticos y otros que pudieran surgir vinculados a la seguridad de la información.

Requerimientos de Seguridad para el desarrollo/adquisición de sistemas de aplicación

1. Modelo de Seguridad Aplicativa

1.1 El usuario utilizado para conectar la base de datos desde la aplicación, debe cumplir los siguientes requerimientos:

- Debe estar configurado de manera de garantizar que sea utilizado solamente para la conexión de la aplicación, a través de una cuenta no logoneable.
- Ninguna credencial debe estar sin codificar (los usuarios y claves no se deben almacenar en el código, ni en ningún archivo en texto plano).
- La contraseña debe poder modificarse a disposición sin afectar la continuidad de la aplicación.
- Las cuentas de servicio o de proceso deben estar especificadas y documentadas, no ser logoneables y no estar asociadas a ningún usuario nominal.
- Las cuentas de instalación deben deshabilitarse/bloquearse luego de la implementación o bien resguardarse en custodia.
- No deben permanecer activas cuentas o usuarios de máximo privilegio que correspondan a la instalación o al soporte.

1.2 No se permitirán conexiones que impacten directamente en la Bases de datos.

1.3 Se deberá garantizar el correcto funcionamiento ante la aplicación de parches o configuraciones de seguridad en cualquiera de las capas de la aplicación, garantizando el soporte del proveedor.

1.4 Desarrollar documentación técnica y funcional detallando la seguridad de:

- El esquema de conexión entre capas de la aplicación.
- El modelo de seguridad de la solución y herramientas utilizadas (propias o de terceras partes).
- Arquitectura de seguridad donde se detallen puertos y servidores que requieren interconectarse.
- Modelo de identificación y autenticación de usuarios de todas las capas de la solución.

1.5 Disponer de consola centralizada para todas las facilidades de administración y parametrización de seguridad.

2. Identificación y Autenticación de usuarios

Se deben realizar las parametrizaciones correspondientes para gestionar el Alta, Baja y Modificación (ABM) de usuarios. Esto incluye configuraciones específicas que aseguren la integridad y seguridad de la información relacionada con los usuarios.

2.1 Integración de Soluciones Cloud

- **Integración con Azure AD para Autenticación:** La solución debe integrarse con Azure Active Directory (Azure AD) para centralizar y gestionar la autenticación. Será necesario que la solución pueda agregarse al tenant MetroGAS mediante SAML SSO, así como poder soportar un segundo factor de autenticación (MFA).
- **Autenticación con ID:** Se requiere que los usuarios autenticuen su identidad mediante un ID único. Para aumentar la seguridad será necesario que el sistema de autenticación este basado en OAuth 2.0.
- **Gestión Segura de Credenciales:** Las credenciales de los usuarios deben ser administradas y transmitidas de forma encriptada al servidor. Para lograr esto, la aplicación debe utilizar el protocolo HTTPS en todas las comunicaciones cliente/servidor.

2.2 Integración de Soluciones On-Premise

- **Configuración del Sistema de Directorio Local:** El aplicativo deberá integrarse con Active Directory para gestionar los usuarios y las credenciales.
- **Configuración de Parámetros de Seguridad:** La comunicación entre la aplicación y el sistema de directorio local deberá estar cifrada. Se deberá utilizar el protocolo seguro LDAPS (LDAP sobre SSL) para la transmisión de los datos.
- **Gestión de Credenciales de Acceso:** No será permitido el manejo de credenciales en texto plano o sin un encriptado que sea administrado directamente por AD.
- **Implementación de Mecanismos de SSO (Single Sign-On):** Considerar la implementación de SSO para reducir la carga de autenticación.

3. Manejo de control de accesos

3.1 La aplicación debe permitir la parametrización de objetos vinculados al sistema de forma tal que pueda establecerse la segregación de funciones de usuarios mediante grupos de Azure AD (Cloud) o grupos de Active Directory (On-Premise).

3.2 La aplicación debe permitir la gestión de tareas segregadas para las áreas de TI, tales como: Administración de Seguridad, Monitoreo de eventos, Soporte funcional a usuarios de la aplicación, Administración de Base de Datos, etc.

3.3 La aplicación no tiene que mantener información en memoria que esté vinculada al acceso del usuario.

4. Administración de integraciones entre aplicaciones

La solución debe asegurar la integridad y confiabilidad en la integración de aplicaciones (interfaces, API, etc), a través de mecanismos de control.

4.1 Los esquemas de identificación, autenticación y control de acceso de las integraciones deben:

- Configurarse utilizando certificación de claves públicas y privadas.
- Contar con los mínimos privilegios para funcionar.
- Securizar los repositorios de origen y destino de las integraciones - repositorios.

4.2 Configurar un transporte seguro (canal) de la información encriptada.

4.3 En caso de utilizar API's o desarrollos de terceros deberán garantizar que cumpla con los estándares de este Anexo y proporcionar la documentación de seguridad pertinente.

4.4 Integraciones mediante API

Autenticación y Autorización:

- Implementar autenticación de dos factores para acceder a las integraciones con API.
- Garantizar que los tokens de acceso tengan una vigencia limitada.

Encriptación y Protección de Datos:

- Exigir el uso de protocolos de encriptación como TLS/SSL para la transmisión de datos.
- Aplicar técnicas de encriptación para proteger la información almacenada en la API.

Control de Acceso y Privilegios:

- Establecer un modelo de privilegios mínimos, asignando permisos de manera específica y limitada.
- Implementar controles de acceso basados en roles para restringir el acceso

Prevención de Ataques:

- Aplicar filtros de seguridad para prevenir ataques comunes como inyecciones SQL.
- Implementar medidas de prevención de ataques de denegación de servicio (DDoS).

Registro y Monitoreo:

- Registrar todas las actividades y eventos relevantes de la API.

Gestión de Ciclo de Vida de API:

- Mantener un proceso formalizado para la gestión de versiones de la API.
- Incluir información sobre las medidas de seguridad para el consumo de la API.

Parches y Actualizaciones:

- Implementar un proceso para la aplicación oportuna de parches de seguridad.
- Garantizar que las actualizaciones no comprometan la seguridad y sean compatibles con versiones anteriores.

5. Administración de registro de eventos

5.1 Es necesario que la solución posea un sistema de registro y almacenamiento de eventos de forma segura. Entre ellos, son indispensables los siguientes:

- Eventos críticos propios de la aplicación.
- Eventos de seguridad aplicativa, teniendo en cuenta como obligatorios:
 - ✓ ABM de usuarios y sus propiedades.
 - ✓ ABM de roles / grupos / perfiles.
 - ✓ Variaciones en la configuración de la aplicación.
 - ✓ Fecha de último ingreso de usuarios.
 - ✓ Utilización de transacciones para cada usuario.

5.2 Restricción de acceso a los registros de eventos, de forma tal que solo personal autorizado pueda visualizarlo.

5.3 Los eventos registrados no deben permitir modificaciones, ya sea tanto desde el aplicativo como fuera de él.

5.4 La aplicación debe contar con herramientas de depuración que permita configurar el tiempo de retención de los registros.

6. Aplicaciones Mobile

Las aplicaciones que se ejecuten en un dispositivo móvil deberán tener en consideración las siguientes prácticas de seguridad.

Sistemas Operativos:

- iOS (Apple): El aplicativo deberá ser compatible con versiones de iOS compatibles y que reciban actualizaciones de seguridad. No serán admitidos OS que estuvieran en end of life.
- Android: El aplicativo deberá ser compatible con versiones de Android que aun tengan actualizaciones de seguridad.

Protección de Datos:

- Utilizar técnicas de hashing seguras para almacenar contraseñas y otros datos sensibles.
- Evitar el almacenamiento de datos sensibles en la memoria caché de las aplicaciones.

Autenticación y Autorización:

- Integrar la aplicación con soluciones de gestión de identidad para garantizar la autenticación y autorización adecuadas.
- No permitir el control de acceso a funciones y datos sensibles.

Gestión de Dispositivos Móviles (MDM):

- El aplicativo deberá estar disponible en PlayStore y AppStore.
- El aplicativo deberá poder ser distribuido por la herramienta de gestión mdm disponible en MetroGAS.
- Será obligatorio poder inhabilitar el acceso a los datos del aplicativo ante casos de pérdida o robo.

Políticas de Contraseña:

- Android e iOS: Implementa políticas de contraseñas sólidas, incluyendo requisitos de longitud, caracteres especiales y cambios periódicos. Fomenta el uso de métodos de autenticación biométrica.

7. Reportes

La aplicación debe contar con la posibilidad de realizar reportes y consultas a demanda.

Minimamente se deberá poder obtener la siguiente información:

- Detalle de ABM en perfiles, grupos, roles o cualquier forma de agrupación.

- ABM de usuarios por período.
- Histórico de estados de usuario.
- Detalle de los parámetros de las políticas de usuario implementados.
- Usuarios asignados a cada uno de los perfiles, grupos, etc.
- Detalle con fecha de la última utilización de cada transacción, ya sea por usuario o por grupo, rol o función.
- Histórico ingresos a la aplicación de cada usuario (no tomar fecha de validación en LDAP)
- Detalle de la fecha de última utilización de cada transacción asignada por cada usuario.
- Consumo de Licencias.

8. Manejo de comunicaciones en términos de Seguridad Informática

- 8.1 La comunicación entre las distintas capas y/o componentes que constituyen la aplicación deben transmitirse por medios seguros y encriptados.
- 8.2 En los casos donde parte de los componentes y/o capas se encuentren en servicios en la nube, o fuera de la red de MetroGAS, la comunicación (autenticación y tráfico de información) entre la aplicación y/o cliente web, debe realizarse mediante métodos seguros, con encriptación de datos sin excepción. Asimismo debe soportar la utilización de certificados digitales.
- 8.3 En el caso de interacción de servicios en la nube con servidores propios de la compañía, debe cifrarse la comunicación.
- 8.4 Se tienen que separar los servidores web y de bases de datos, ubicando el servicio web en la DMZ y el servicio de base de datos en un entorno privado. Se recomienda cifrar las comunicaciones entre ambos servicios.
- 8.5 Se tienen que separar los servidores productivos de los de testing, ubicando los productivos en una VLAN y los de testing en otra.
- 8.6 Toda instalación deberá consultarse previamente a Seguridad Informática para alocala en el segmento de red correspondiente. La segregación de redes es rigurosa.
- 8.7 De requerir interacción con componentes OT deberá validarse previamente los protocolos disponibles y la viabilidad del mismo.

9. Almacenamiento de Datos

- 9.1 Se deberán poder aplicar las parametrizaciones de seguridad definidas en el standard de MetroGAS para el motor de base de datos donde resida la información aplicativa.
- 9.2 Asegurar la integridad de la información almacenada en las bases de datos de la aplicación, permitiendo prevenir y detectar cualquier cambio que pueda sufrir la información de forma directa (sin que intervenga la aplicación), como por ejemplo, el uso de dígito verificador horizontal y vertical en las tablas de cada base.

10. Mantenimiento y Soporte

- 10.1 Los esquemas de trabajo de la administración de la solución, no deben requerir que personal del área de Desarrollo o terceros desarrolladores requieran acceder al ambiente de Producción para el desempeño de sus tareas asignadas.
- 10.2 Los accesos al personal de implementación/soporte solo se otorgarán a ambientes no productivos y por tiempo limitado.

11. Aplicaciones y Servicios Web

- 11.1 Las aplicaciones del tipo web, deberán poder publicarse utilizando el protocolo seguro https, y permitiendo inhabilitar el protocolo no seguro http. Lo mismo aplica para aquellas aplicaciones que hagan uso de cualquier otro tipo de protocolo, deben permitir la configuración de puertos seguros.
- 11.2 Se deberá evitar el acceso directo por URL a cualquier página del sitio sin previa autenticación y/o autorización.
- 11.3 Evitar el uso de variables que se envíen dentro de la URL, conteniendo información confidencial o crítica.
- 11.4 Compatibilidad con los protocolos de cifrado fuertes y no obsoletos. A su vez, se deberá poder deshabilitar el uso de algoritmos de cifrado débiles en el servidor web, sin alterar el normal funcionamiento de la aplicación.
- 11.5 La información referente a la cadena de conexión hacia la base de datos y/o credenciales de usuarios de servicio, almacenada en archivos de configuración, no deberá estar en texto plano sin que se encuentre encriptada de forma segura.
- 11.6 Utilizar mecanismos de autenticación cliente-servidor que sean seguros y confiables.

- 11.7 Incluir configuraciones que permitan establecer el tiempo de inactividad antes de que una sesión de usuario caduque.
- 11.8 Compatibilidad con navegadores Chrome y Edge. Permitiendo la actualización de los mismos, con soporte del proveedor.
- 11.9 Preferentemente utilizar el estándar HTML5. No se acepta el uso de complementos como Flash o Silverlight.

12. Programación Segura

El desarrollo de la aplicación deberá tener en cuenta el top 10 de OWASP de forma tal de prevenir ataques y aumentar los niveles de seguridad. Para mayor información ver: <https://owasp.org/www-project-top-ten/>

13. Auditabilidad y controles

- 13.1 Se informa que MetroGAS podrá realizar auditorías a los proveedores, antes y durante la prestación de servicios, en los casos que se amerite o se considere necesario, con la finalidad, de validar y verificar el cumplimiento de documentación, procesos o requisitos solicitados.
- 13.2 MetroGAS podrá ejecutar anualmente un escaneo sobre la solución con el objetivo de identificar vulnerabilidades en la plataforma, en las funcionalidades de la aplicación, en los servidores o los servicios que la componen y determinar un nivel de riesgo asociado. La metodología que se aplicará estará basada en las buenas prácticas recomendadas por NIST-800-115 y los hallazgos serán clasificados por severidad según lo establece el CVE. Los ajustes que surjan de esta evaluación estarán a cargo del proveedor.
- 13.3 Si la solución propuesta es una solución SAAS, el proveedor deberá presentar evidencia para acreditar el estado de los controles definidos en ISAE 3402 y/o SSAE18 informe SOC1 tipo 2.

14. Incidentes de Ciberseguridad

La Contratista se compromete a:

- 14.1 Disponer de una persona para interactuar ante un ciberincidente con conocimientos sólidos de Tecnología y Ciberseguridad, dicho contacto deberá ser

- informado (mail, TE de contacto) a los responsables de la Gerencia de Seguridad Informática de MetroGAS S.A.
- 14.2 Poseer mecanismos o procesos para evitar la fuga de información, detectar y prevenir violaciones de datos, filtraciones o destrucción no deseada de datos, tanto de MetroGAS SA, como de todas sus participados.
- 14.3 Informar de forma inmediata a MetroGAS S.A. ante incidentes de ciberseguridad ya sea que se produzcan en su propio entorno o en empresas asociadas con las que tenga relación y que, dependiendo del alcance, naturaleza y/o tiempo en que se produzca/n el/los ciberincidente/s, se haya afectado o se previera que pudieran afectar cualquier tipo de información perteneciente a MetroGAS S.A. o continuidad del servicio brindado.
- 14.4 Disponer de un plan documentado de respuesta ante incidentes de ciberseguridad que incluya la capacidad de recuperación de los sistemas/datos y los logs necesarios para poder realizar un análisis forense siguiendo las normas existentes o normas ISO 27037, ISO 27035, ISO 27002, NIST, Informe ISAE 3402 y/o SSAE18, etc.

Se entiende por "**incidente de ciberseguridad**" a un evento o serie de eventos inesperados o no deseados, que tienen una probabilidad significativa de comprometer las operaciones del negocio; provocando una pérdida o uso indebido de información, interrupción parcial o total de los sistemas, la conectividad o la integridad e inviolabilidad de los datos.

Los datos necesarios del incidente a informar, dentro de los 4 días corridos, son:

- Tipo de incidente, breve descripción y alcance del mismo
- Cuando se descubrió el incidente y si está en curso
- Si detectaron posibilidad de datos robados, alterados, accedidos o se utilizaron con cualquier otro fin no autorizado
- El efecto que produjo el incidente en las operaciones
- La respuesta al incidente, incluyendo si se ha resuelto o se está resolviendo

Deberá informar vía correo electrónico al siguiente mail:

- ✓ dsi_seginfo@metrogas.com.ar

15. Requerimientos específicos para entornos OT

15.1 Para la prestación de Servicios en el entorno OT, el proveedor o sus empleados deben contar con alguna de las siguientes certificaciones/conocimientos:

- IC32 Certificate: ISA/IEC 62443 Cybersecurity Fundamentals Specialist
- IC33 Certificate: ISA/IEC 62443 Cybersecurity Risk Assessment Specialist
- IC34 Certificate: ISA/IEC 62443 Cybersecurity Design Specialist
- IC37 Certificate: ISA/IEC 62443 Cybersecurity Maintenance Specialist
- Certificación en seguridad Funcional ISA84 IEC-61508/61511
- U otras certificaciones recomendables para la gestión de entornos OT

Sólidos conocimientos y experiencia demostrable en:

- SCADA: Sistema de Supervisión Control y Adquisición de Datos
- HMI: Interfaz Humano Maquina
- DCSs: Sistemas de Control Distribuido
- PLCs: Controladores Lógicos Programables
- SISs: Sistemas Instrumentados de Seguridad
- IACS: Sistema de Control de Automatización Industrial
- Diversos Protocolos Industriales
- Sistemas de Gestión de alarmas y respuesta a incidentes industriales ISA 18.2, entre otros.

15.2 Garantizar la seguridad en la cadena de suministro mediante una adecuada, segura y eficiente gestión del ciclo de vida del sistema de control industrial, haciendo foco en la seguridad por diseño basado en estándares internacionales como ISA 62443.

15.3 El proveedor deberá de forma inmediata notificar las vulnerabilidades informadas por los fabricantes u otros entes vinculados al servicio.

15.4 Las estaciones de trabajo que el proveedor tenga que conectar a la red LAN de MetroGAS deberán cumplir con los siguientes requisitos mínimos:

- Estaciones de trabajo con Sistema Operativo Windows. Con los parches de seguridad actualizados. No serán admitido versiones de OS que estuvieran fuera de soporte.
- Estaciones de trabajo con antivirus corporativo licenciado y actualizado.

- Previo a comenzar a trabajar y conectarse a la red de MetroGAS, dichas notebooks tienen que pasar por una revisión del Sector de Seguridad Informática.
- 15.5 En caso de proveer equipos al SCI (Sistemas de Control Industrial), se deben previamente configurar como mínimo en base a las siguientes medidas:
- Eliminar cuentas y contraseñas estándar
 - Aplicar la regla de "Mínima Funcionalidad"
 - Aplicar la regla de "Seguridad por Defecto"
 - Los equipos tienen que poder soportar:
 - ✓ el uso de contraseñas robustas
 - ✓ gestionarse de forma remota
- 15.6 Deberá tener procedimientos de parcheo para aplicaciones, sistemas operativos y firmware. Considerando los parches de seguridad y actualizaciones informadas y/o publicadas por los fabricantes. Los parches de seguridad deben ser aplicados según los procedimientos internos y con la validación y aprobación del fabricante para el sistema que corresponda.
- 15.7 El suministro de servicios y/o ciber activos para el entorno OT debe cumplir con lo establecido en los estándares internacionales, específicamente el estándar **ISA99/IEC 62443** según las normas:
- IEC 62443-2-1 Requerimientos para un CSMS (Cyber Security Management System)
 - IEC 62443-2-4 Requisitos para los proveedores de soluciones
 - IEC 62443-3-3 Requisitos del sistema y niveles de seguridad
- 15.8 Todos los componentes por suministrar para el entorno OT deberían cumplir con el estándar **IEC 62443-4-2** "Requisitos técnicos de seguridad para componentes de control y automatización industrial" y estar certificados por **ISASecure CSA** y en cumplimiento con lo establecido en la norma.